# Software Requirements Specification (SRS)

## LexCorp: Secure Identity, Access Control and Asset Custody Platform

# 1 Introduction

This Software Requirements Specification describes the requirements of LexCorp, a platform for secure identity, access control and custody of digital documents and physical devices. Section 1 introduces the document: its purpose and audience (1.1), the scope of the product (1.2), the terms used (1.3) and how the rest of the document is organised (1.4).

## 1.1 Purpose

The purpose of this SRS is to state completely and unambiguously what LexCorp must do and the constraints under which it must operate, so that it can serve as the agreement between the customer and the development team, the basis for design and implementation, and the reference for testing and acceptance.

**Intended audience:** the customer's representatives (security officers, department managers and auditors), the course instructor and evaluators, the developers and designers of the system, and the testers who will verify the requirements.

## 1.2 Scope

**Product:** LexCorp, a web-based Secure Identity, Access Control and Asset Custody Platform.

**Application domain:** enterprise information security and records management for organisations that handle sensitive documents and equipment. It is a multi-user, browser-based system backed by a private (permissioned) blockchain.

**Objectives and benefits:** LexCorp gives each employee a self-owned cryptographic identity, replaces passwords with passkeys and authenticator codes, enforces permissions in a smart contract that no administrator can bypass, records every approved document and device as a unique token, makes every issued copy traceable and verifiable, and keeps an audit trail that cannot be edited, with explainable detection of insider misuse. This reduces the risk of phishing, insider leaks, forged records and log tampering, speeds up audits and avoids recurring licence costs.

**What the software will do:**

- Register, provision, authenticate and revoke identities; enforce role- and department-based access.
- Register, approve, mint, version, view, share and download documents; register and track physical devices.
- Issue watermarked, QR-verifiable copies and detect tampering of returned copies.
- Record and risk-score every action, raise alerts and support their review and escalation.
- Allow remote access only through a VPN with company sign-in.

**What the software will not do:** it will not store files or personal data on the blockchain, will not run on a public blockchain or charge transaction fees, will not integrate with HR or payroll systems in this version, and its AI will never take action without a human decision.

These statements are consistent with the problem analysis and feasibility study, which is the higher-level document for this project.

## 1.3 Definitions, acronyms, and abbreviations

**Table 1:** *Definitions, acronyms and abbreviations*

| Term | Definition |
|---|---|
| Asset | A document (digital asset) or a device (physical asset) managed by LexCorp |
| Blockchain / ledger | A shared, append-only record kept identically by several nodes; here a private Hyperledger Besu network |
| DID | Decentralized Identifier (W3C); here did:ethr:<wallet address> |
| Wallet | A public/private key pair (Ethereum format) generated in the user's browser; the address is public, the key stays on the device |
| NFT | Non-fungible token (ERC-721): a unique on-chain record representing one asset |
| Mint | Create an NFT on the ledger for an approved asset |
| Smart contract | A program on the ledger that enforces rules; here the AssetNFT contract |
| QBFT | A Byzantine-fault-tolerant consensus protocol used by the validator nodes |
| Passkey | A WebAuthn/FIDO2 credential unlocked by the device's fingerprint, face or PIN |
| TOTP | Time-based One-Time Password from an authenticator app (RFC 6238) |
| Factor 2 / Factor 3 (F2/F3) | Purpose-bound proofs: F2 for viewing and submitting, F3 for approving, minting, modifying, downloading and administration |
| Step-up grant | Single-use, short-lived proof that F2 or F3 was satisfied for one named action |
| SHA-256 | Cryptographic hash function used to fingerprint files |
| Watermarked copy | A copy generated for one viewer, marked with their identity, network address, time, action ID and a QR code |
| RBAC | Role-Based Access Control |
| VPN / SSO / OIDC | Virtual Private Network / Single Sign-On / OpenID Connect |
| Audit event | An append-only record of an action, with actor, role, time, address and risk level |
| CRT / VW / DL / MOD ID | Action identifiers for creation, view, download and modification (e.g. VW-20260928-0001) |
| SRS, UML, API, UI | Software Requirements Specification, Unified Modeling Language, Application Programming Interface, User Interface |

## 1.4 Organization

Section 2 gives an overall description of the product: its context and interfaces, its main functions with a goal diagram, its users, constraints, assumptions and the requirements deferred to later versions. Section 3 lists the specific functional and non-functional requirements with hierarchical numbering. Section 4 models the requirements with UML: a use case diagram and use case descriptions, a class diagram with a data dictionary, representative scenarios with sequence diagrams, state diagrams for the key classes, and an activity diagram. Section 5 describes the prototype, how to run it and sample scenarios with screen captures. Section 6 lists the references and Section 7 gives the point of contact.

# 2 Overall Description

This section describes the factors that affect the product and its requirements: where it fits (2.1), what it does (2.2), who uses it (2.3), the constraints (2.4), the assumptions (2.5) and what is deferred (2.6).

## 2.1 Product Perspective

LexCorp is a new, self-contained product that replaces several separate tools (user directory, document store, asset register and log viewer) with one system. Figure 1 is a level-0 data flow diagram (notation: rectangles are external entities, ovals are processes, cylinders are data stores and arrows are data flows).

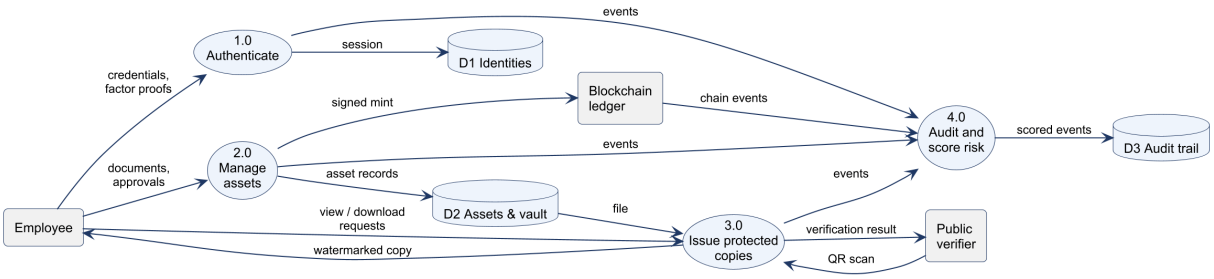



**Figure 1:** *Level-0 data flow diagram*

Figure 2 is the block diagram of the product (notation: packages group components by layer, arrows show dependencies).

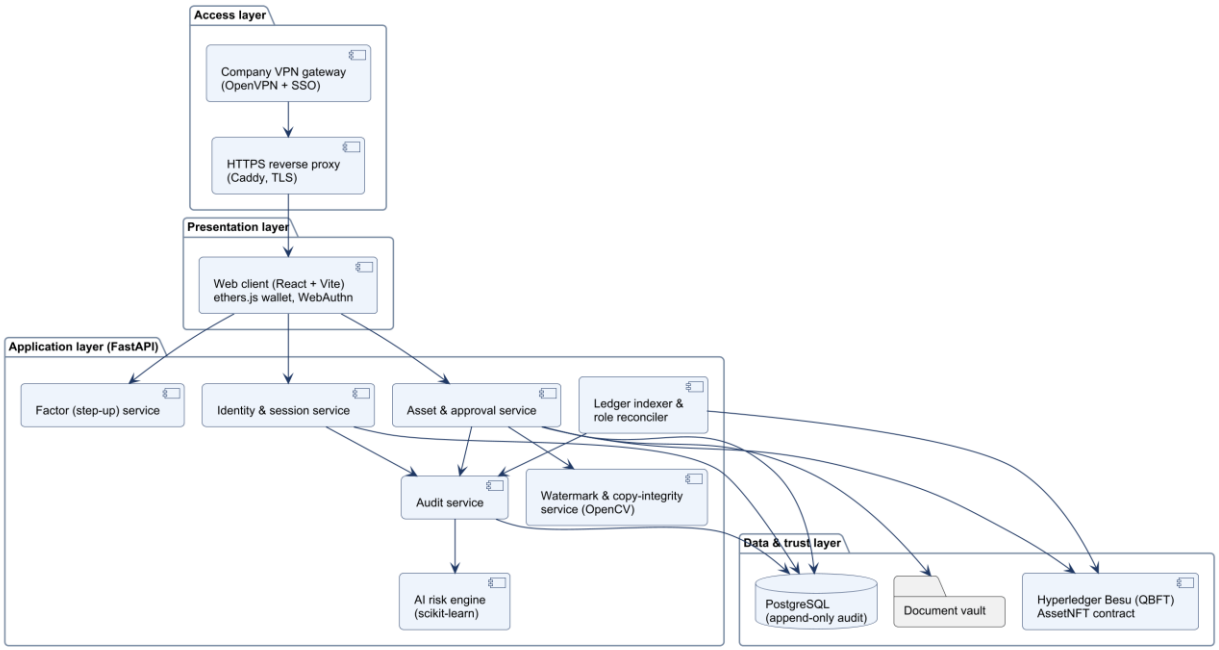



**Figure 2:** *Block diagram (layered architecture)*

## Interface constraints:

**Table 2:** *Interface constraints*

| Interface | Description |
|---|---|
| System interfaces | Hyperledger Besu JSON-RPC (transactions, receipts, events); company identity provider over OpenID Connect at the VPN gateway |
| User interfaces | Responsive web UI for desktop, tablet and phone; role-specific dashboards; every sensitive action shows a Factor 2/3 confirmation dialog; plain-language messages |
| Hardware interfaces | Platform authenticator (fingerprint, face, PIN) or security key for passkeys; phone camera to scan QR codes; no special hardware on the server |
| Software interfaces | Modern browser with WebAuthn (Chrome, Edge, Firefox, Safari); authenticator app (Google/Microsoft Authenticator); OpenVPN Connect client; PostgreSQL 15+; Docker |
| Communication interfaces | HTTPS (TLS 1.2+) to the application; OpenVPN for remote users; WireGuard between VPN gateway and site; REST/JSON API |

## Other constraints:

- **Memory:** a pilot installation (application, database and three validator nodes) must run on one server with 32 GB RAM; the browser client must run on devices with 4 GB RAM.
- **Operations:** the system runs continuously; backups of the database and document vault are taken daily; validators are monitored; administrators rotate server keys when required.
- **Site adaptation:** each organisation configures its own departments, roles, approval rules, allowed VPN accounts, network addresses and host names at installation.

## 2.2 Product Functions

The major functions of LexCorp are summarised below in customer terms.

**Table 3:** *Product functions*

| Function | Summary |
|---|---|
| Identity management | Administrators register people; each person creates a wallet on their own device, activates it with a one-time PIN and enrols a passkey and an authenticator code. |
| Secure sign-in | Passwordless sign-in; one session per person; automatic sign-out after 15 minutes of inactivity. |
| Purpose-bound confirmation | Viewing and submitting need Factor 2; approving, minting, downloading and administration need Factor 3. |
| Document custody | Upload, approval by a manager, minting as an NFT signed by the approver's own wallet, versions and revocation. |
| Protected copies | Every view or download is a personalised watermarked copy with a QR code; returned copies are checked for tampering. |
| Controlled sharing | Owners share documents with view limits and expiry; downloads need owner consent and manager approval. |
| Device custody | Register devices by serial and MAC or unique address, detect duplicates, mint to the custodian, print QR labels. |
| Audit and AI monitoring | Every action is recorded and risk-scored; unusual behaviour raises an alert with plain-word reasons. |
| Alert handling | Alerts go Auditor → Manager → Administrator; only the Administrator can revoke an identity. |
| Remote access | Off-site staff connect through a VPN that asks for the company sign-in at every connection. |

**High-level goal diagram.** Figure 3 decomposes the overall goal into sub-goals and the means that achieve them (notation: each box is a goal; an arrow from a goal to a box means the box contributes to achieving that goal; boxes at the right are operational means realised by requirements in Section 3).

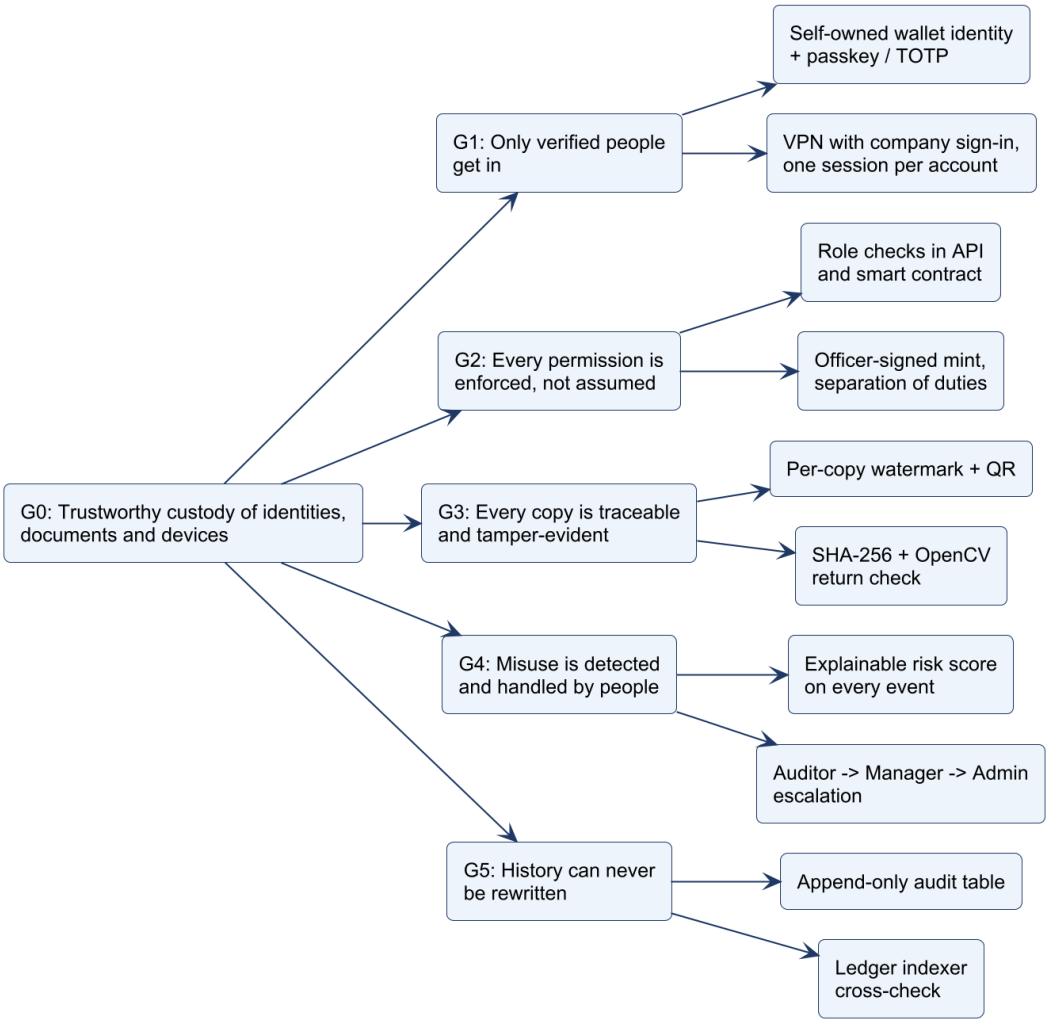



**Figure 3:** *High-level goal diagram*

## 2.3 User Characteristics

**Table 4:** *User characteristics*

| User class | Background and skill level | Frequency of use |
|---|---|---|
| User (employee) | Office staff; basic computer and smartphone skills; no blockchain knowledge expected | Daily |
| Manager | Department head; familiar with approval workflows | Daily |
| Auditor | Security or compliance officer; understands logs and investigations | Weekly or on alert |
| Administrator | IT or security administrator; comfortable with identity management and servers | Weekly or on request |
| Public verifier | Anyone holding a copy or device label; only needs a phone camera | Occasional |

## 2.4 Constraints

- **Regulatory:** personal data must stay off-chain and be correctable (Digital Personal Data Protection Act, 2023); security logs must be kept for at least 180 days (CERT-In Directions, 2022).
- **Hardware limits:** a pilot must run on a single on-premises server; no cloud dependency except the VPN gateway.
- **Interfaces:** only open standards (HTTPS, WebAuthn, TOTP, OpenID Connect, ERC-721).
- **Security:** private keys must never leave the user's device; the server key must never be able to mint.
- **Licensing:** only open-source components with permissive licences may be used.

**Safety-critical properties** (if violated, security is lost):

- A user who does not hold the MINTER role on the contract must never be able to create an asset.
- A proof for one action must never be accepted for another action or a second time.
- An audit event, once written, must never be modified or deleted.
- A revoked identity must lose all sessions and on-chain roles immediately.
- A tampered copy must never be accepted as a new version.

**Other properties** (if violated, the system will not perform properly): the blockchain must have enough validators online to reach consensus; the server clock must be synchronised for TOTP and expiry checks; the database and ledger must remain consistent, which the indexer checks continuously.

## 2.5 Assumptions and Dependencies

- Users have a device with a passkey-capable authenticator (fingerprint, face or PIN) or an authenticator app.
- Users keep their wallet recovery phrase safe; losing both device and phrase requires an administrator reset.
- The organisation provides a server, a company identity provider for the VPN, and host names with TLS certificates.
- At least three validator nodes run (four or more across sites in production for fault tolerance).
- Browsers are recent versions that support WebAuthn and modern JavaScript.
- The organisation's network allows VPN (UDP) traffic to the gateway.

## 2.6 Approportioning of Requirements

The following requirements are beyond the scope of the current version and may be addressed in future releases:

- Integration with HR and payroll systems for automatic onboarding and exit.
- Hardware security modules (HSM) for the server's operator key.

- Native mobile applications (the current web application is responsive).
- Verifiable credentials exchanged with other organisations (inter-organisation trust).
- Retraining the risk model automatically from auditor feedback.
- Multi-site validator deployment with automatic failover.

## 3 Specific Requirements

The requirements are numbered hierarchically; use cases in Section 4 refer to them by number (for example, Req 4.3).

**1. Identity registration and provisioning**

**1.1.** Only an Administrator shall register an identity, entering name, role, department and the person's wallet address, and confirming with Factor 3.

**1.2.** The system shall issue a single-use provisioning PIN that is shown once, stored only as a hash and expires after 3 hours.

**1.3.** The wallet shall be generated in the person's own browser; the private key shall never be sent to the server and shall be stored on the device only as an encrypted keystore.

**1.4.** The system shall derive the person's decentralised identifier as did:ethr:<wallet address>.

**1.5.** Before any other function becomes available, the person shall enrol a login authenticator (TOTP) and a login passkey.

**1.6.** A person shall be able to register up to 10 passkeys per purpose (for different devices); adding or removing one shall require the login factor.

**1.7.** A locked-out person shall be able to request a reset; only an Administrator shall approve it (Factor 3), which removes old login factors, issues a new PIN and ends all sessions. There shall be no self-service reset.

**2. Authentication and session management**

**2.1.** Sign-in shall require the wallet address plus a valid login TOTP code or login passkey assertion.

**2.2.** Challenges and TOTP codes shall be single-use; a replayed challenge or already-used TOTP time step shall be rejected.

**2.3.** The session shall be held in a secure HttpOnly cookie that client-side scripts cannot read.

**2.4.** Only one session per account shall be active; a new sign-in shall end the older session, and both sides shall be recorded in the audit trail.

**2.5.** A session shall end after 15 minutes of inactivity, after 30 minutes in total, or when the client's network address changes.

**2.6.** Viewing and submitting shall require a Factor 2 proof; approving, minting, modifying, downloading and administration shall require a Factor 3 proof.

**2.7.** Each Factor 2/3 proof shall be single-use, short-lived and bound to one named action.

**2.8.** Authentication endpoints shall be rate-limited to resist brute-force attempts.

## 3. Role-based access control

**3.1.** The system shall support four roles: Administrator, Manager, Auditor and User.

**3.2.** Managers shall act only on identities and assets of the departments they manage.

**3.3.** Nobody shall approve their own request or decide on a security alert about themselves.

**3.4.** On-chain roles (MINTER, ANCHOR, MANAGER, AUDITOR) shall be granted and revoked automatically when an identity's role changes; the server's operator key (REGISTRAR) shall only grant and revoke roles and shall never hold an operational role itself.

**3.5.** Every permission shall be checked by the server and, for ledger actions, by the smart contract; hiding a control in the user interface shall not be relied upon for security.

## 4. Digital asset (document) management

**4.1.** The system shall accept PDF, Word, PowerPoint, Excel, PNG and JPEG files up to 50 MB, determining the type from the file content, not the extension.

**4.2.** On upload (Factor 2) the system shall compute the file's SHA-256 fingerprint, store the file off-chain and issue a creation ID (CRT-YYYYMMDD-NNNN) with state pending approval.

**4.3.** A Manager (own departments) or Administrator shall approve or reject the submission with Factor 3; on approval the approver's own wallet shall sign the transaction that mints the document as an NFT to the owner's DID, carrying the file hash.

**4.4.** The system shall record a mint only after checking both the transaction receipt and the resulting contract state.

**4.5.** A modification shall be made through an approved modification copy (MOD-ID); the approved revision shall be anchored as a new version of the same asset; originals shall never be overwritten and the full version history shall be kept.

**4.6.** Free transfers and approvals of NFTs shall be disabled; custody transfer and revocation (burn) shall require the MANAGER role on the contract.

## 5. Protected copies and verification

**5.1.** Every view shall produce a fresh watermarked copy showing CONFIDENTIAL, the viewer's name, short wallet address, network address, date and a unique View ID, with a QR code on every page and a document-control page.

**5.2.** Word, PowerPoint and Excel files shall be shown as watermarked PDFs; the original file shall not be handed out by viewing.

**5.3.** Scanning a copy's or device's QR code shall open a public verification page that states whether it is authentic, without revealing the viewer's name or address to anonymous users.

**5.4.** When a copy is returned as a revision, the system shall decode its QR codes (OpenCV) and compare every watermark field with the stored record; a changed, removed or mismatched watermark shall be refused and shall raise a tamper alert with the evidence (page and field).

**5.5.** The uploader shall not be told the result of the tamper check; Managers and Administrators shall see the evidence, and approval shall be blocked while the alert is open.

## 6. Controlled sharing and downloads

**6.1.** An owner shall be able to delegate access to another identity with a view limit and/or an expiry time; viewing and downloading shall be separate permissions; a User's delegation shall require Manager approval.

**6.2.** Each successful view under a delegation shall be counted atomically; views beyond the limit or after expiry shall be refused and recorded.

**6.3.** A download shall require a request (Factor 2), the owner's consent (Factor 3), a Manager's approval (Factor 3) and a one-time fetch (Factor 3) identified by a download ID; the downloaded file shall carry a watermark naming the downloader and the owner.

## 7. Physical asset management

**7.1.** A Manager or Administrator shall register a device with serial number, MAC address or unique device address, department, location and custodian.

**7.2.** Serial numbers, MAC addresses and device addresses shall be unique across the system after normalisation; duplicates shall be refused.

**7.3.** After approval by another officer the device shall be minted as an NFT to the custodian's DID, and a QR label shall be available.

**7.4.** The public QR page shall show only minimal fields; MAC address, device address and location shall be visible only to Managers and Auditors.

**7.5.** Device status (active, assigned, maintenance, in storage, lost, retired, decommissioned) and maintenance records shall be kept, with maintenance logs fingerprinted.

## 8. Audit, monitoring and alerts

**8.1.** Every action shall create an audit event recording actor, the actor's role at that moment, time, asset, network address, result and a risk level.

**8.2.** The audit table shall be append-only, enforced by the database itself: updates and deletes shall be rejected.

**8.3.** A ledger indexer shall read contract events and cross-check them with the database, flagging unapproved mints, mismatched data and unexpected role grants.

**8.4.** A locally hosted risk model shall score events using 32 behaviour features compared with the person's own 30-day history, and shall give plain-word reasons for each score.

**8.5.** A high-risk event shall raise at most one open alert per person per 24 hours; alerts shall move Auditor → Manager → Administrator, each able to dismiss or forward.

**8.6.** Only an Administrator shall revoke an identity from an alert (Factor 3); revocation shall end all sessions immediately and remove the person's on-chain roles.

**8.7.** Auditors and Administrators shall be able to filter the audit trail by category, role, risk, result, escalation state, asset, identity and date range.

## 9. Remote access

**9.1.** The application shall not be reachable from the internet; off-site access shall be possible only through the organisation's VPN.

**9.2.** Every VPN connection shall require sign-in with the company identity provider (OpenID Connect), and only approved accounts shall be admitted.

**9.3.** Each VPN connection shall receive its own network address, so that sessions can be bound to it.

## 10. Non-functional requirements

**10.1.** **Security:** all traffic shall use TLS; authenticator secrets shall be encrypted at rest; only hashes, token numbers and DIDs shall be written on-chain.

**10.2.** **Performance:** typical page actions shall respond within 2 seconds on the office network; the ledger shall produce a block every 2 seconds so that a mint is confirmed within a few seconds; a copy of a 50-page PDF shall be generated within 10 seconds.

**10.3.** **Reliability and availability:** the ledger shall continue operating when one validator fails (with four or more validators); database and vault backups shall be taken daily.

**10.4.** **Usability:** the interface shall work on desktop, tablet and phone, use plain language and require no blockchain knowledge.

**10.5.** **Privacy and compliance:** the system shall meet the Digital Personal Data Protection Act, 2023 (personal data off-chain) and keep security logs for at least 180 days.

**10.6.** **Maintainability:** the code shall be modular (separate services) and covered by automated unit, contract and end-to-end tests.

**10.7.** **Portability:** all components shall run in Docker containers on Windows or Linux, including air-gapped networks.

**10.8.** **Cost:** no licence or per-transaction fees shall be required.

# 4 Modeling Requirements

This section bridges the application domain and the machine domain using UML. For each diagram type the notation is described first.

## 4.1 Use Case Diagram

**Notation.** Stick figures are actors (people or external systems, marked «system»); ovals are use cases; the rectangle is the system boundary; a solid line links an actor to a use case it takes part in; a dashed arrow labelled «include» means the use case always includes another one. Figure 4 shows the use case diagram of LexCorp.

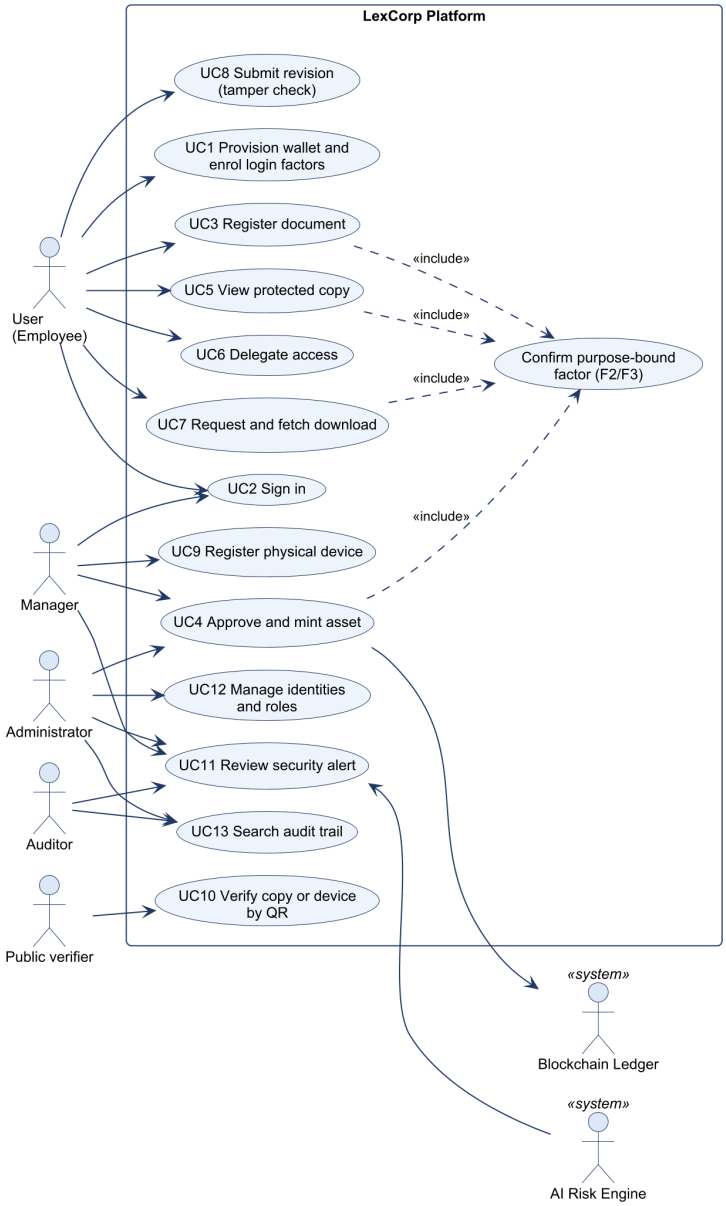



**Figure 4:** *Use case diagram*

## 4.2 Use Case Descriptions

Each goal in Figure 3 is satisfied by one or more use cases, and each use case refers to the requirements in Section 3.

| **Use case** | UC1: Provision wallet and enrol login factors |
|---|---|
| **Actors** | User (any role) |
| **Goal satisfied** | G1 |
| **Preconditions** | Administrator has registered the person's wallet address and issued a PIN. |
| **Main flow** | 1. Person opens First-time provisioning and enters recovery phrase (or key) and PIN.<br>2. System verifies the PIN and wallet.<br>3. Browser stores the encrypted keystore.<br>4. Person enrols login TOTP and login passkey.<br>5. System activates the identity. |
| **Alternative flows** | 2a. PIN wrong or expired: refused and recorded.<br>4a. Person leaves before enrolling: no other function is available. |
| **Postconditions** | Identity active; audit events recorded. |
| **Requirements** | 1.2–1.6, 2.2 |

| **Use case** | UC2: Sign in |
|---|---|
| **Actors** | User, Manager, Auditor, Administrator |
| **Goal satisfied** | G1 |
| **Preconditions** | Identity active; login factors enrolled. |
| **Main flow** | 1. Person enters wallet address and chooses passkey or TOTP.<br>2. System issues a challenge; device signs it.<br>3. System verifies, ends any other session, sets the session cookie.<br>4. Dashboard is shown. |
| **Alternative flows** | 3a. Invalid proof: refused, LOGIN_FAILED recorded.<br>3b. Identity revoked: refused. |
| **Postconditions** | One active session; LOGIN recorded and risk-scored. |
| **Requirements** | 2.1–2.5, 2.8, 8.1 |

| **Use case** | UC3: Register document |
|---|---|
| **Actors** | User, Manager, Administrator |
| **Goal satisfied** | G2, G3 |
| **Preconditions** | Signed in; Factor 2 available. |
| **Main flow** | 1. Person chooses a file, title, department and (optionally) owner.<br>2. Person confirms Factor 2.<br>3. System checks type and size, computes SHA-256, stores the file and issues a CRT-ID.<br>4. Request appears in the approval queue. |
| **Alternative flows** | 3a. Unsupported type or too large: refused. |
| **Postconditions** | Asset pending approval. |
| **Requirements** | 4.1, 4.2, 2.6 |

| | |
|---|---|
| **Use case** | UC4: Approve and mint asset |
| **Actors** | Manager, Administrator, Blockchain Ledger |
| **Goal satisfied** | G2 |
| **Preconditions** | A pending request exists in the approver's departments; approver is not the requester. |
| **Main flow** | 1. Approver opens the request and confirms Factor 3.<br>2. System prepares the mint transaction.<br>3. Approver's wallet signs it.<br>4. Contract checks the MINTER role and mints.<br>5. System verifies receipt and state and marks the asset minted. |
| **Alternative flows** | 1a. Approver rejects with a reason.<br>4a. Signer lacks MINTER role: contract reverts; nothing recorded as minted. |
| **Postconditions** | NFT exists on the ledger bound to the owner's DID. |
| **Requirements** | 3.2–3.5, 4.3, 4.4 |

| | |
|---|---|
| **Use case** | UC5: View protected copy |
| **Actors** | User (owner or grantee), Manager, Administrator |
| **Goal satisfied** | G3 |
| **Preconditions** | Signed in; permitted to view (owner, in-scope manager, or usable grant). |
| **Main flow** | 1. Person opens the document and confirms Factor 2.<br>2. System checks permission and, for a grant, consumes one view.<br>3. System generates a watermarked copy with View ID and QR.<br>4. Copy is displayed. |
| **Alternative flows** | 2a. Limit reached or expired: refused and recorded. |
| **Postconditions** | VIEW action and audit event recorded. |
| **Requirements** | 5.1, 5.2, 6.2 |

| | |
|---|---|
| **Use case** | UC6: Delegate access |
| **Actors** | User (owner), Manager, Administrator |
| **Goal satisfied** | G2 |
| **Preconditions** | Owner signed in; document minted. |
| **Main flow** | 1. Owner chooses grantee, view limit, expiry and whether downloads may be requested.<br>2. Owner confirms the required factor.<br>3. For a User, a Manager approves; for a Manager/Admin in scope the grant is immediate. |
| **Alternative flows** | 3a. Manager rejects. |
| **Postconditions** | Active grant. |
| **Requirements** | 6.1 |

| | |
|---|---|
| **Use case** | UC7: Request and fetch download |
| **Actors** | User, Manager |
| **Goal satisfied** | G3 |
| **Preconditions** | Person may view the document. |
| **Main flow** | 1. Requester asks for a download (Factor 2).<br>2. Owner consents (Factor 3).<br>3. Manager approves (Factor 3).<br>4. Requester fetches once (Factor 3) and receives a watermarked file. |
| **Alternative flows** | 2a/3a. Consent or approval refused.<br>4a. Second fetch: refused. |
| **Postconditions** | DL action completed. |
| **Requirements** | 6.3 |

| **Use case** | UC8: Submit revision (tamper check) |
|---|---|
| **Actors** | User |
| **Goal satisfied** | G3 |
| **Preconditions** | An approved modification copy (MOD-ID) was issued. |
| **Main flow** | 1. User uploads the edited copy (Factor 3).<br>2. System decodes QR codes and compares watermark fields.<br>3. If intact, watermark layers are removed and the revision waits for approval as a new version. |
| **Alternative flows** | 2a. Watermark changed or removed: revision refused, tamper alert raised; uploader not told. |
| **Postconditions** | New version pending, or tamper alert open. |
| **Requirements** | 4.5, 5.4, 5.5 |

| **Use case** | UC9: Register physical device |
|---|---|
| **Actors** | Manager, Administrator |
| **Goal satisfied** | G2 |
| **Preconditions** | Signed in with Factor 3. |
| **Main flow** | 1. Officer enters serial, MAC or unique address, department, location and custodian.<br>2. System checks global uniqueness.<br>3. Another officer approves; device minted to the custodian; QR label available. |
| **Alternative flows** | 2a. Duplicate: refused and recorded. |
| **Postconditions** | Device NFT minted. |
| **Requirements** | 7.1–7.3, 7.5 |

| **Use case** | UC10: Verify copy or device by QR |
|---|---|
| **Actors** | Public verifier |
| **Goal satisfied** | G3 |
| **Preconditions** | Verifier holds a copy or device label. |
| **Main flow** | 1. Verifier scans the QR code.<br>2. System looks up the action or token and shows whether it is authentic, with minimal fields. |
| **Alternative flows** | 2a. Unknown or revoked: shown as not authentic. |
| **Postconditions** | None (read-only). |
| **Requirements** | 5.3, 7.4 |

| **Use case** | UC11: Review security alert |
|---|---|
| **Actors** | Auditor, Manager, Administrator, AI Risk Engine |
| **Goal satisfied** | G4 |
| **Preconditions** | An alert exists in the reviewer's stage. |
| **Main flow** | 1. AI (or a rule) raises an alert with reasons.<br>2. Auditor dismisses or forwards to Manager.<br>3. Manager dismisses or forwards to Administrator.<br>4. Administrator dismisses or revokes the identity (Factor 3). |
| **Alternative flows** | Reviewer is the subject of the alert: not allowed. |
| **Postconditions** | Alert closed; if revoked, sessions ended and on-chain roles removed. |
| **Requirements** | 8.4–8.6, 3.3 |

| **Use case** | UC12: Manage identities and roles |
|---|---|
| **Actors** | Administrator |
| **Goal satisfied** | G1, G2 |
| **Preconditions** | Signed in with Factor 3. |
| **Main flow** | 1. Administrator registers, changes role or department, approves resets or revokes.<br>2. System updates on-chain roles automatically and records the change. |
| **Alternative flows** | — |
| **Postconditions** | Registry and contract roles consistent. |
| **Requirements** | 1.1, 1.7, 3.4 |

| **Use case** | UC13: Search audit trail |
|---|---|
| **Actors** | Auditor, Administrator |
| **Goal satisfied** | G5 |
| **Preconditions** | Signed in. |
| **Main flow** | 1. Reviewer sets filters.<br>2. System lists matching events with risk levels and details. |
| **Alternative flows** | — |
| **Postconditions** | None (read-only). |
| **Requirements** | 8.1–8.3, 8.7 |

## 4.3 Class Diagram

**Notation.** Each box is a class with its name, attributes and operations; a solid line is an association with multiplicities at its ends (1, *, 0..1); an arrow to an «enumeration» shows the allowed values; a dashed arrow is a dependency. Figure 5 shows the key classes of LexCorp.

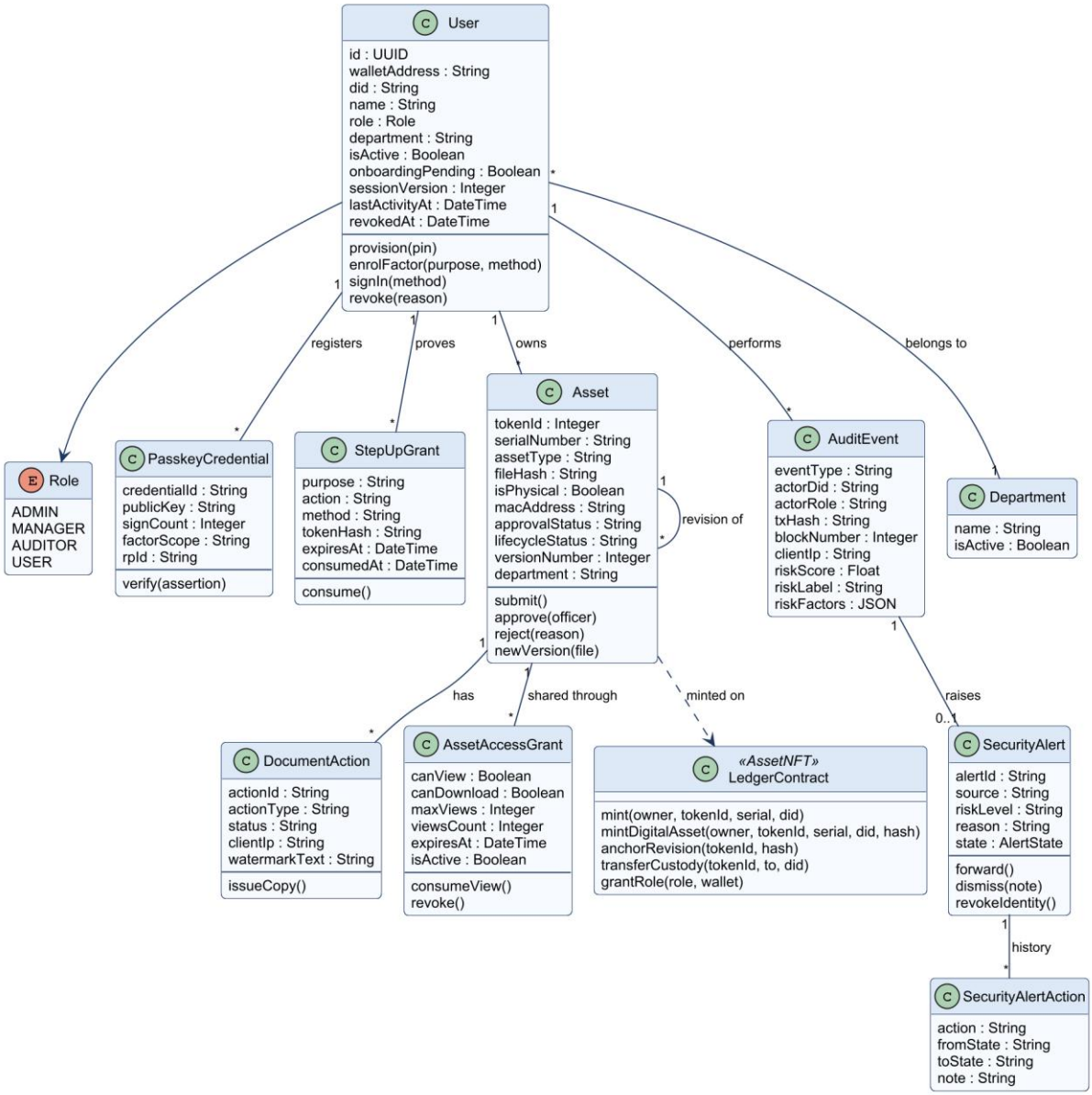



**Figure 5:** *Class diagram*

## Data dictionary

**User**: A person with an identity in the system.

| Attribute | Type | Description |
|---|---|---|
| id | UUID | Primary key |
| walletAddress | String(42) | Public wallet address, unique |
| did | String | did:ethr identifier |
| name | String | Display name |
| role | Role | ADMIN, MANAGER, AUDITOR or USER |
| department | String | Home department |
| isActive / onboardingPending | Boolean | Status flags |
| sessionVersion | Integer | Incremented to end older sessions |
| lastActivityAt / revokedAt | DateTime | Idle timeout and revocation time |

*Operations:* provision(pin), enrolFactor(purpose, method), signIn(method), revoke(reason). *Relationships:* owns 0.. *Asset; registers 0..* PasskeyCredential; proves 0.. *StepUpGrant; belongs to 1 Department; performs 0..* AuditEvent.

**PasskeyCredential**: A WebAuthn credential registered on one device.

| Attribute | Type | Description |
|---|---|---|
| credentialId | String | Credential identifier |
| publicKey | String | Public key for verification |
| signCount | Integer | Counter against cloned authenticators |
| factorScope | String | login, factor2 or factor3 |
| rpId | String | Site the passkey is bound to |

*Operations:* verify(assertion). *Relationships:* belongs to 1 User.

**StepUpGrant**: Single-use proof that Factor 2/3 was satisfied for one action.

| Attribute | Type | Description |
|---|---|---|
| purpose | String | factor2 or factor3 |
| action | String | Named action it is valid for |
| method | String | TOTP or PASSKEY |
| tokenHash | String | Hash of the token given to the browser |
| expiresAt / consumedAt | DateTime | Lifetime and use |

*Operations:* consume(). *Relationships:* belongs to 1 User.

**Asset**: A document or physical device under custody.

| Attribute | Type | Description |
|---|---|---|
| tokenId | Integer | NFT token number |
| serialNumber | String | Asset identifier, unique |
| assetType | String | DOCUMENT, EQUIPMENT, ... |
| fileHash | String(64) | SHA-256 of the file |
| isPhysical / macAddress | Boolean / String | Device fields |
| approvalStatus / lifecycleStatus | String | Approval and lifecycle state (Figure 11) |
| versionNumber | Integer | Version in the lineage |
| department | String | Owning department |

*Operations:* submit(), approve(officer), reject(reason), newVersion(file). *Relationships:* owned by 1 User; has 0.. *DocumentAction; shared through 0..* AssetAccessGrant; revision of 0..1 Asset; minted on LedgerContract.

**DocumentAction**: A view, download, creation or modification of an asset.

| Attribute | Type | Description |
|---|---|---|
| actionId | String | CRT/VW/DL/MOD-YYYYMMDD-NNNN |
| actionType | String | VIEW, DOWNLOAD, CREATION, MODIFICATION |
| status | String | PENDING, APPROVED, COMPLETED, REJECTED |
| clientIp | String | Network address of the actor |
| watermarkText | String | Exact watermark issued, used for tamper checks |

*Operations:* issueCopy(). *Relationships:* belongs to 1 Asset.

**AssetAccessGrant**: Delegated access to an asset.

| Attribute | Type | Description |
|---|---|---|
| canView / canDownload | Boolean | Separate permissions |
| maxViews / viewsCount | Integer | Limit and usage |
| expiresAt | DateTime | Expiry |
| isActive | Boolean | False when revoked |

*Operations:* consumeView(), revoke(). *Relationships:* belongs to 1 Asset; grantee identified by DID.

**AuditEvent**: An append-only record of an action.

| Attribute | Type | Description |
|---|---|---|
| eventType | String | e.g. LOGIN, DOCUMENT_VIEWED, AssetMinted |
| actorDid / actorRole | String | Who acted and their role at that moment |
| txHash / blockNumber | String / Integer | Ledger reference for chain events |
| clientIp | String | Network address |
| riskScore / riskLabel / riskFactors | Float / String / JSON | Risk result and reasons |

*Operations:* — (insert only). *Relationships:* performed by 1 User; raises 0..1 SecurityAlert.

**SecurityAlert**: A high-risk event under human review.

| Attribute | Type | Description |
|---|---|---|
| alertId | String | ALT identifier |
| source | String | AI or RULE |
| riskLevel / reason | String | Level and plain-word reason |
| state | AlertState | Figure 13 |

*Operations:* forward(), dismiss(note), revokeIdentity(). *Relationships:* raised by 1 AuditEvent; history 0..* SecurityAlertAction.

**SecurityAlertAction**: One step in an alert's history.

| Attribute | Type | Description |
|---|---|---|
| action | String | FORWARDED, DISMISSED, IDENTITY_REVOKED |
| fromState / toState | String | Transition |
| note | String | Reviewer's note |

*Operations:* —. *Relationships:* belongs to 1 SecurityAlert.

**Department**: An organisational unit.

| Attribute | Type | Description |
|---|---|---|
| name | String | Unique name |
| isActive | Boolean | Status |

*Operations:* —. *Relationships:* has 0..* User.

**LedgerContract (AssetNFT)**: The smart contract on the permissioned ledger.

*Operations:* mint(...), mintDigitalAsset(...), anchorRevision(tokenId, hash), transferCustody(tokenId, to, did), grantRole(role, wallet). *Relationships:* records the ownership of every Asset.

## 4.4 Representative Scenarios and Sequence Diagrams

**Notation.** Each vertical line is the lifeline of an actor or object (an instance of a class in Figure 5, e.g. the API Server works on User, Asset and AuditEvent objects); horizontal arrows are messages in time order (numbered); dashed arrows are replies; «alt» boxes show alternatives with their conditions.

### Scenario 1: Sign in (UC2)

Meera, a User, opens LexCorp on her laptop, enters her wallet address and chooses her passkey. The server sends a single-use challenge; Windows Hello asks for her PIN; the signed assertion is verified against her PasskeyCredential. Her older session on another device is ended (sessionVersion increases), a LOGIN AuditEvent is written and scored, and her dashboard opens.

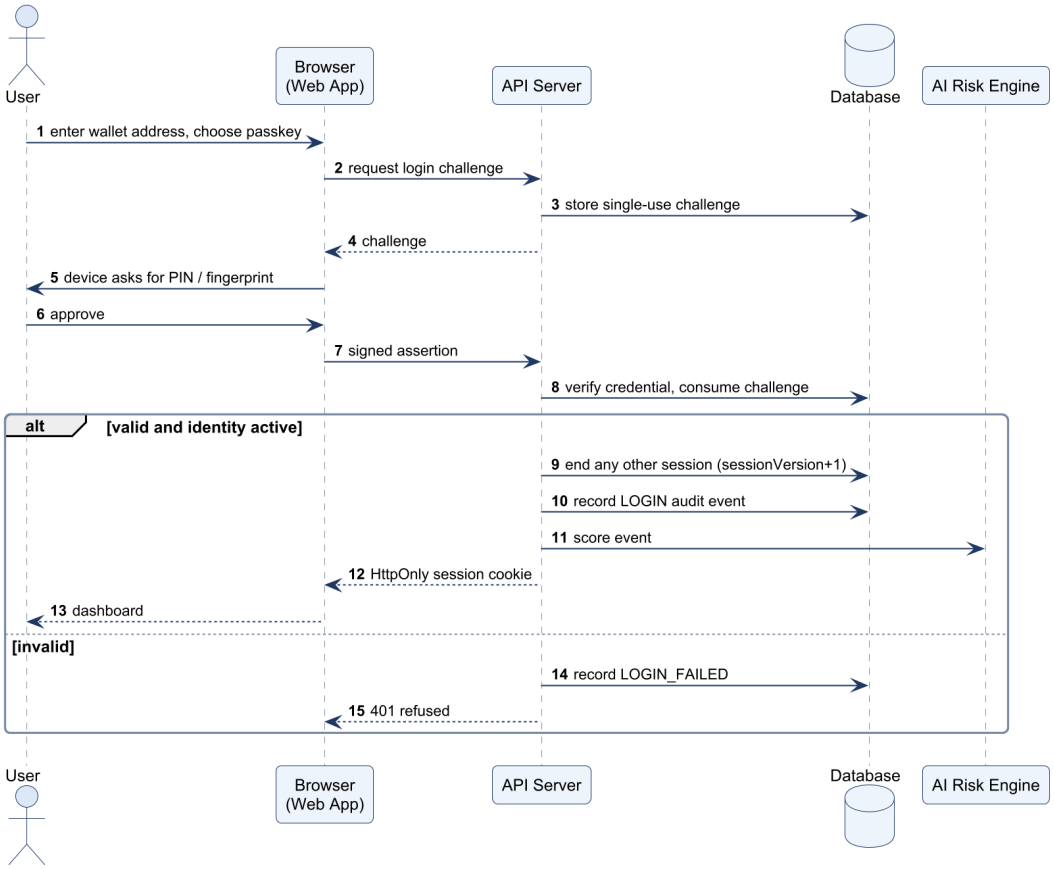



**Figure 6:** *Sequence diagram: sign in*

### Scenario 2: Register, approve and mint a document (UC3, UC4)

Meera uploads a PDF and confirms Factor 2. The server stores it, records its SHA-256 and creates Asset TEST-01 in state PendingApproval with creation ID CRT-20260928-0001. Ravi, the department Manager, opens the request and confirms Factor 3; his own wallet signs the mint; the AssetNFT contract checks that Ravi holds MINTER_ROLE and mints token 6 in block 94925. The server verifies the receipt and token state and marks the Asset minted.

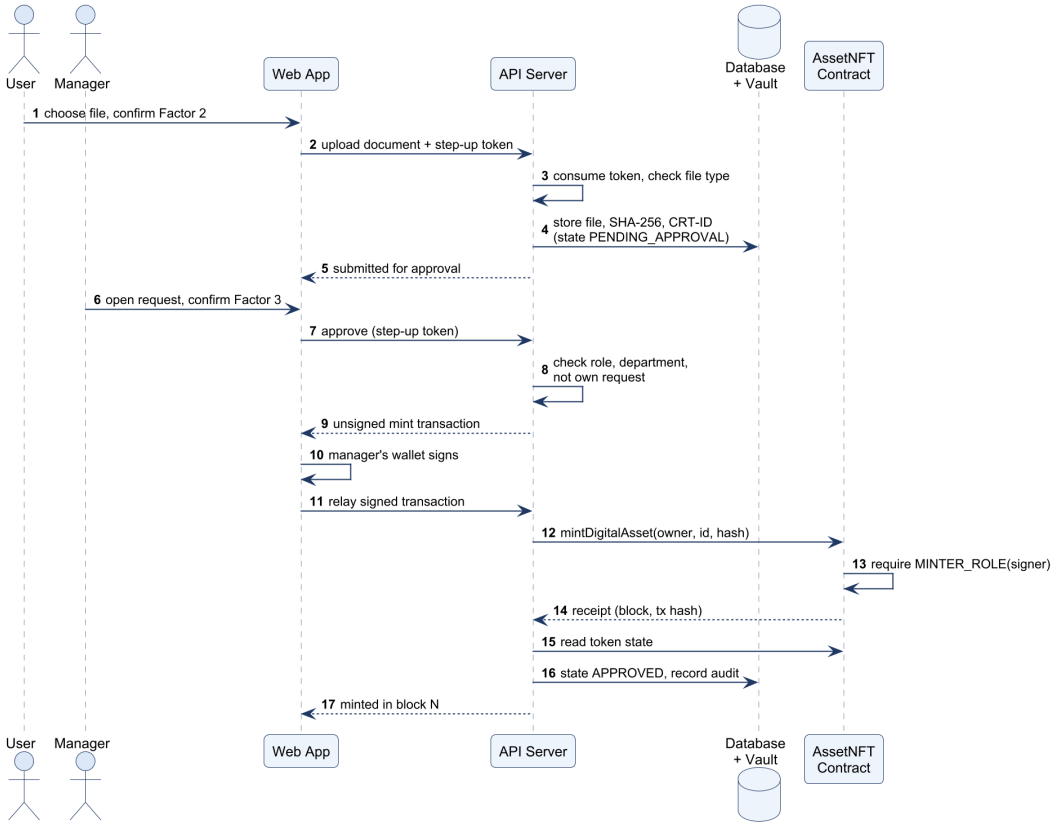



**Figure 7:** *Sequence diagram: register, approve and mint*

### Scenario 3: Delegate access with a view limit (UC6, UC5)

The owner delegates TEST-01 to Arjun with a limit of two views. Arjun opens it twice; each time one view is consumed from the AssetAccessGrant and a new watermarked copy (VW-ID) is produced with his name, wallet, address and a QR code. His third attempt is refused and an ACCESS_LIMIT_REACHED AuditEvent is written.

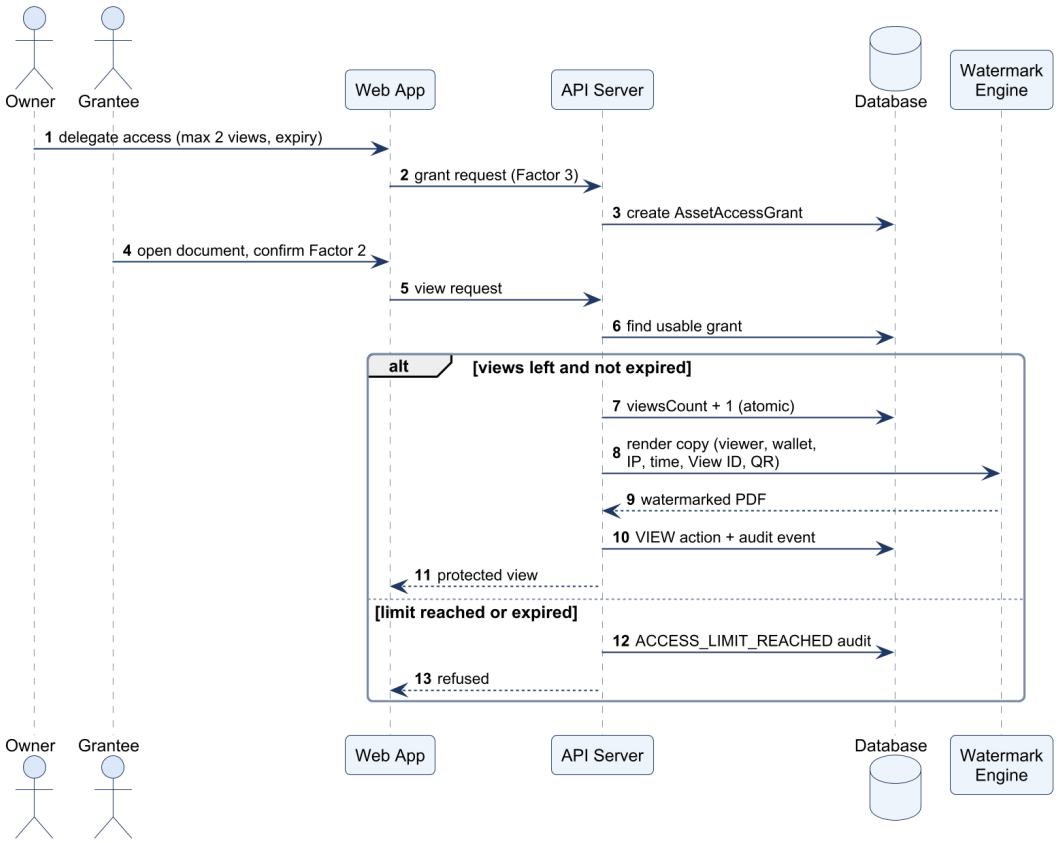



**Figure 8:** *Sequence diagram: delegated view with a limit*

### Scenario 4: Tampered revision (UC8)

Arjun receives a modification copy MOD-20260928-0001, edits the watermark's network address and uploads it as a revision. The copy-integrity checker decodes the QR codes with OpenCV and finds that the watermark field no longer matches the DocumentAction record. The revision is refused, a TAMPER AuditEvent and a SecurityAlert are raised, and Ravi's attempt to approve is blocked while the alert is open.

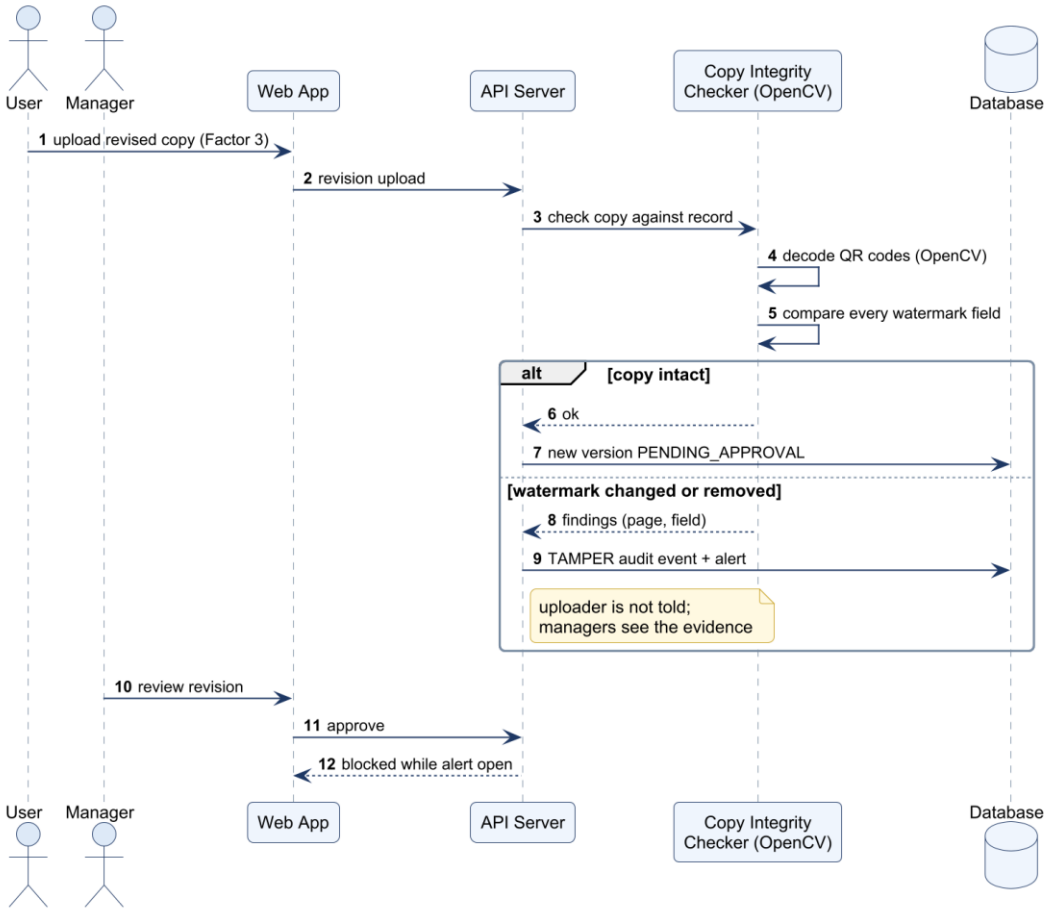



**Figure 9:** *Sequence diagram: tamper check on a returned copy*

### Scenario 5: Alert escalation and revocation (UC11)

The risk engine scores Arjun's burst of downloads outside working hours as HIGH and raises a SecurityAlert with the reasons. The Auditor forwards it to the Manager, who forwards it to the Administrator. The Administrator confirms Factor 3 and revokes Arjun's identity: his sessions end and his on-chain roles are removed.

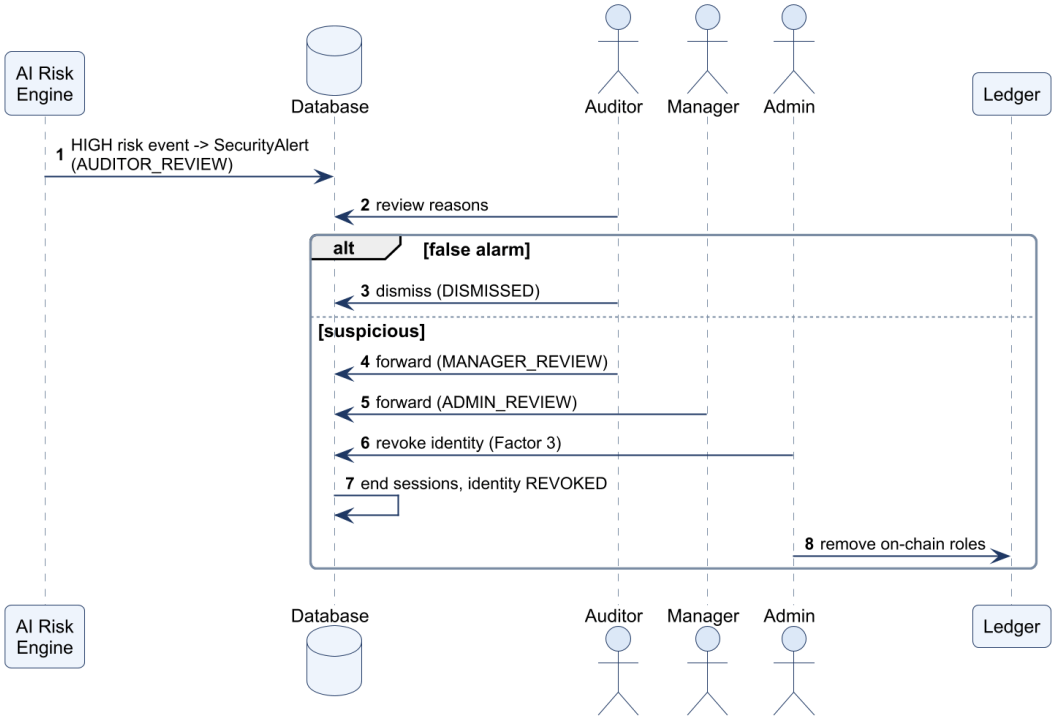



**Figure 10:** *Sequence diagram: alert escalation and revocation*

## 4.5 State Diagrams

**Notation.** Rounded boxes are states; the filled circle is the initial state and the ringed circle the final state; an arrow is a transition labelled *event [guard]*. The events are operations of the classes in Figure 5 and the guards use their attributes (for example viewsCount and maxViews).

A document is submitted into PendingApproval; approval with Factor 3 and the officer's signature mints it; a tampered revision moves it to UnderSecurityReview until the alert is closed; a newer approved version makes it Obsolete; revocation burns it. Scenarios 2 and 4 follow this diagram.

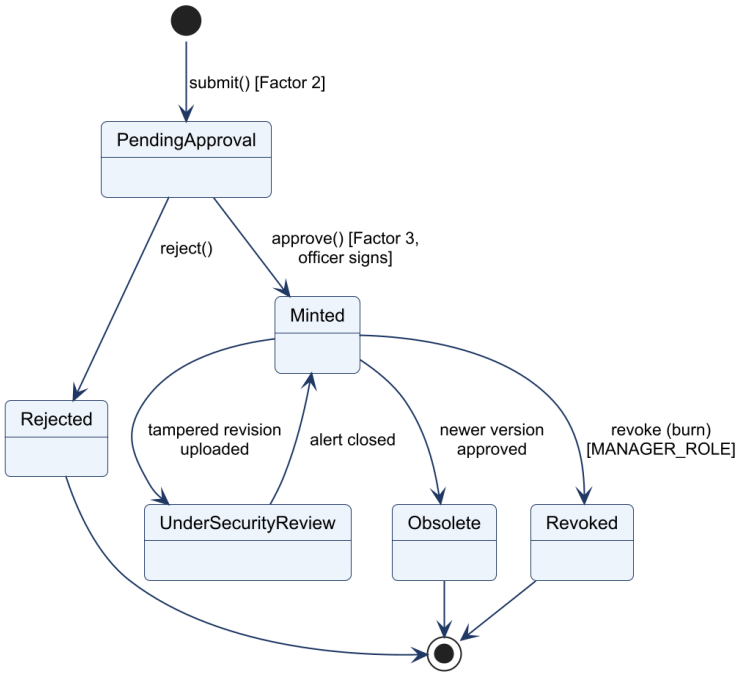



**Figure 11:** *State diagram: Asset (document)*

Each consumeView() keeps the grant Active while viewsCount is below maxViews and exhausts it at the limit; expiry or revocation also ends it. Scenario 3 follows this diagram.

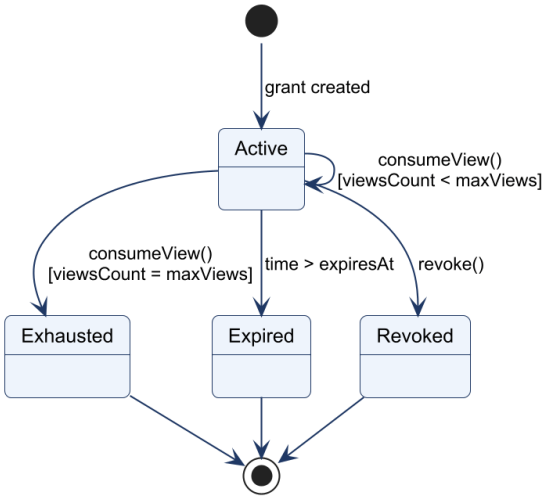



**Figure 12:** *State diagram: AssetAccessGrant*

An alert moves from AuditorReview to ManagerReview to AdminReview through forward(); any reviewer can dismiss it; only the Administrator can end it with revokeIdentity(). Scenarios 4 and 5 follow this diagram.

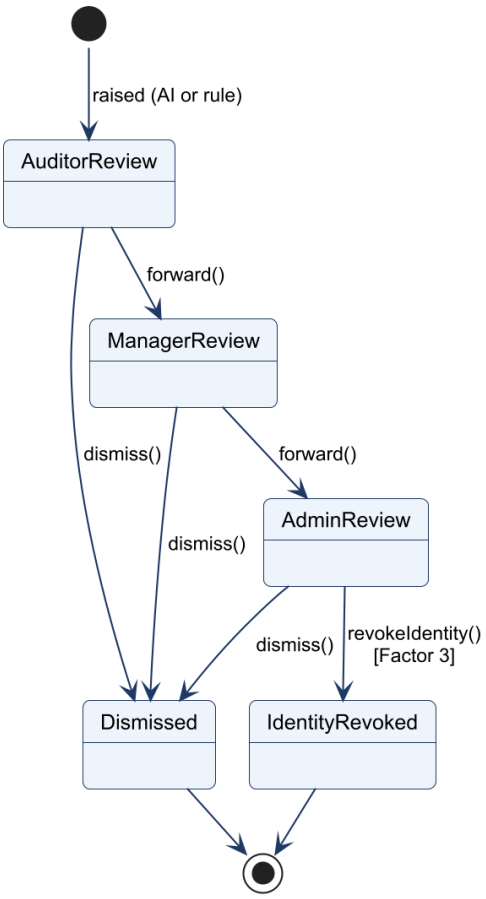



**Figure 13:** *State diagram: SecurityAlert*

An identity is Registered by an Administrator, Provisioned with the one-time PIN, becomes Active once both login factors are enrolled, can request a reset (back to Registered with a new PIN) and is finally Revoked. Scenarios 1 and 5 follow this diagram.

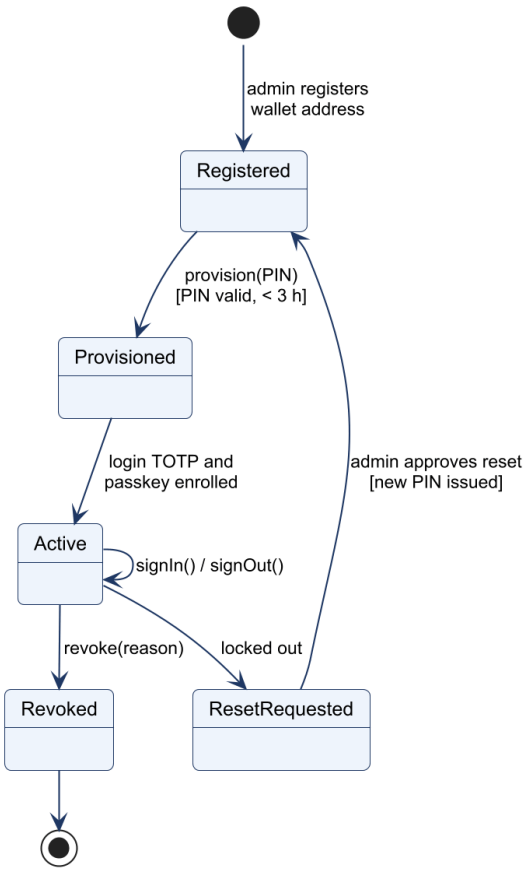



**Figure 14:** *State diagram: User identity*

**Validation.** Every scenario in Section 4.4 corresponds to a path through these state diagrams; every event used in them is an operation in the class diagram, and every variable used in a guard is an attribute declared in the class diagram.

### 4.6 Activity Diagram

**Notation.** Swimlanes separate who performs each activity; rounded boxes are activities; the diamond is a decision with its outcomes; the filled and ringed circles mark start and end. Figure 15 shows the document approval workflow.

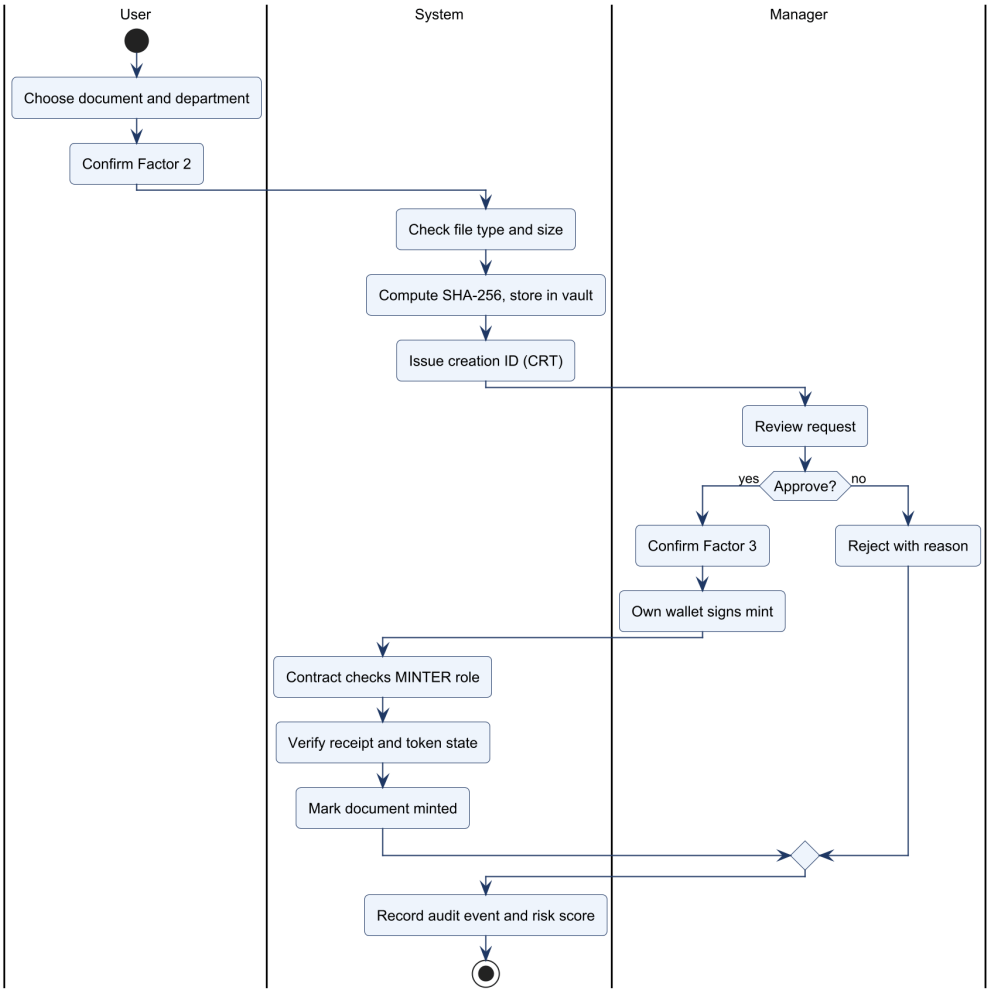



**Figure 15:** *Activity (swimlane) diagram: document approval*

## 5 Prototype

The prototype is a working web application that demonstrates the complete flow of the requirements: identity provisioning and passkey sign-in, role-specific dashboards, document registration, approval and minting on the permissioned ledger, watermarked viewing, delegation with view limits, controlled download, tamper detection on returned copies, physical device registration with QR labels, the audit trail with risk levels, AI alerts and their escalation, and remote access through the VPN.

## 5.1 How to Run Prototype

- **Server configuration:** Windows or Linux with Docker, Python 3.11+, Node.js 20+ and PostgreSQL 15+; 8 CPU cores and 32 GB RAM recommended (the three blockchain validators run as containers).
- **Start-up:** start the Besu network (docker compose), deploy the AssetNFT contract (Hardhat), run the database migrations, start the FastAPI backend and the React frontend; the repository README lists the exact commands.
- **Client:** any modern browser with WebAuthn support; an authenticator app on a phone; for passkeys, a device with fingerprint, face or PIN.
- **Network constraints:** the prototype is deliberately not published on the internet. On the office network it is reached at https://lexcorp-app.duckdns.org; remote users first connect with OpenVPN Connect, which asks for the company sign-in, and then open the same address.
- **Plug-ins:** none are required; the wallet is built into the web application.

## 5.2 Sample Scenarios

The following scenario uses real data from a verification run of the prototype (test identities of the Cyber Security and Radar departments).

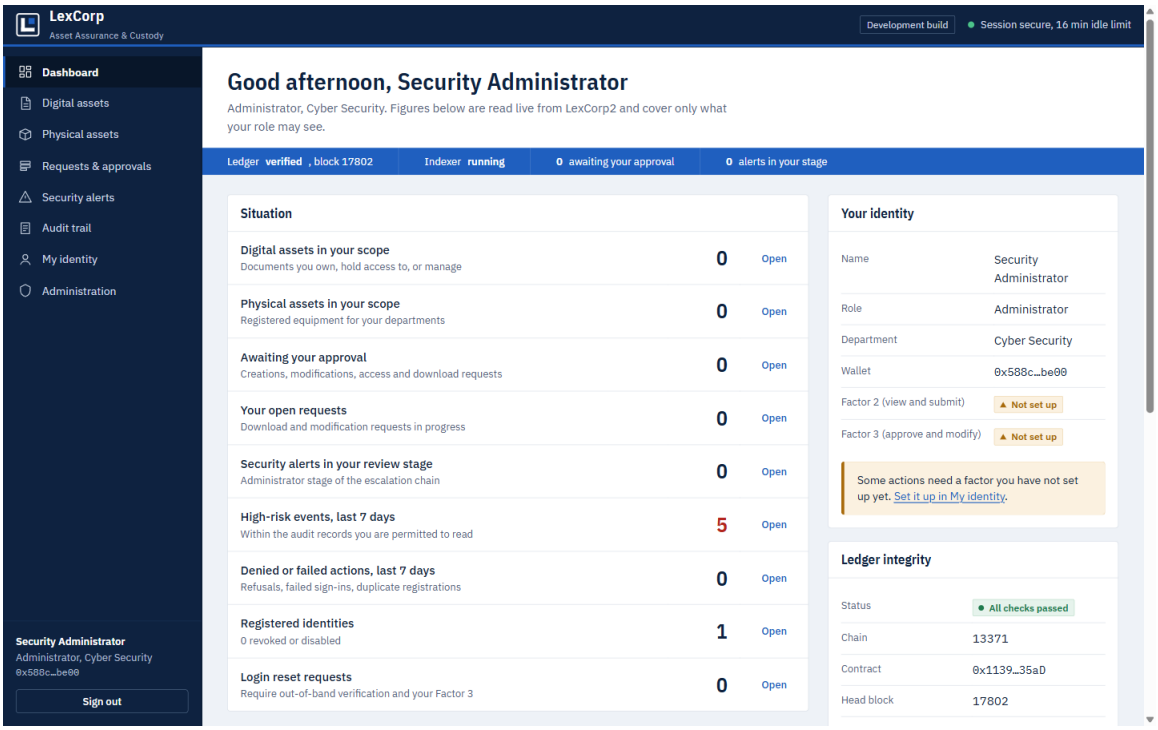



**Figure 16:** *Administrator dashboard: live ledger status, pending approvals, alerts and identity summary.*

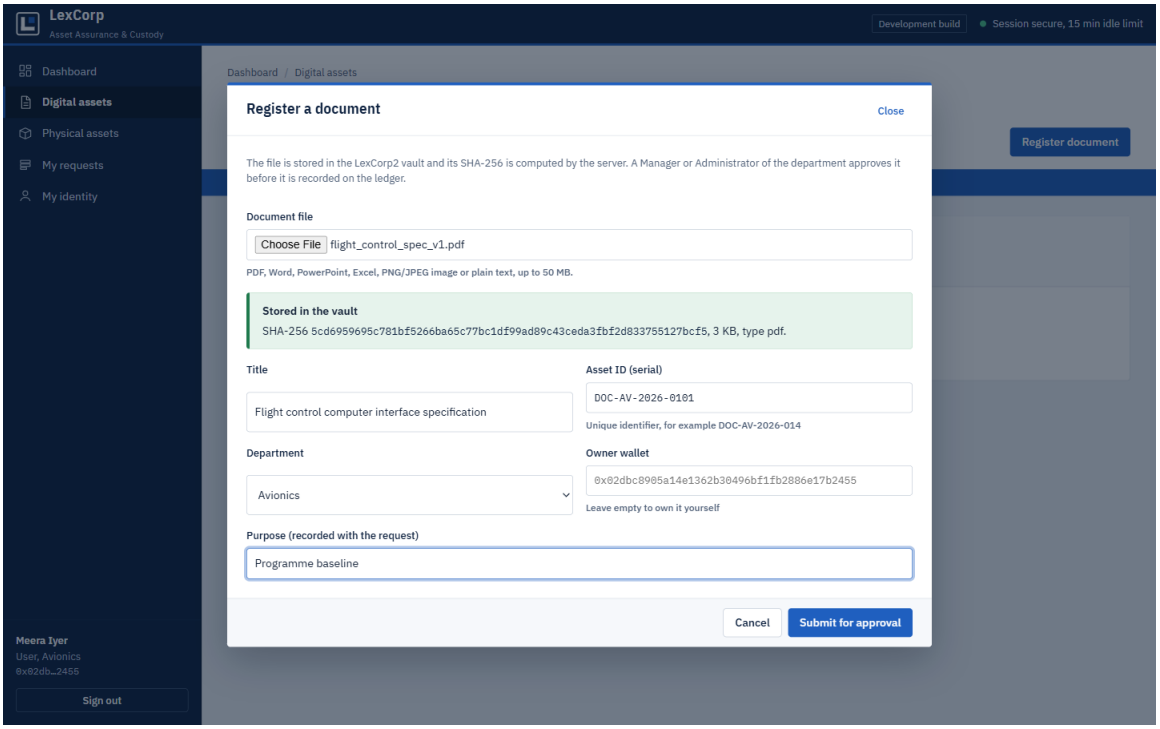



**Figure 17:** *A User registers a document; the file is fingerprinted with SHA-256 and waits for approval.*

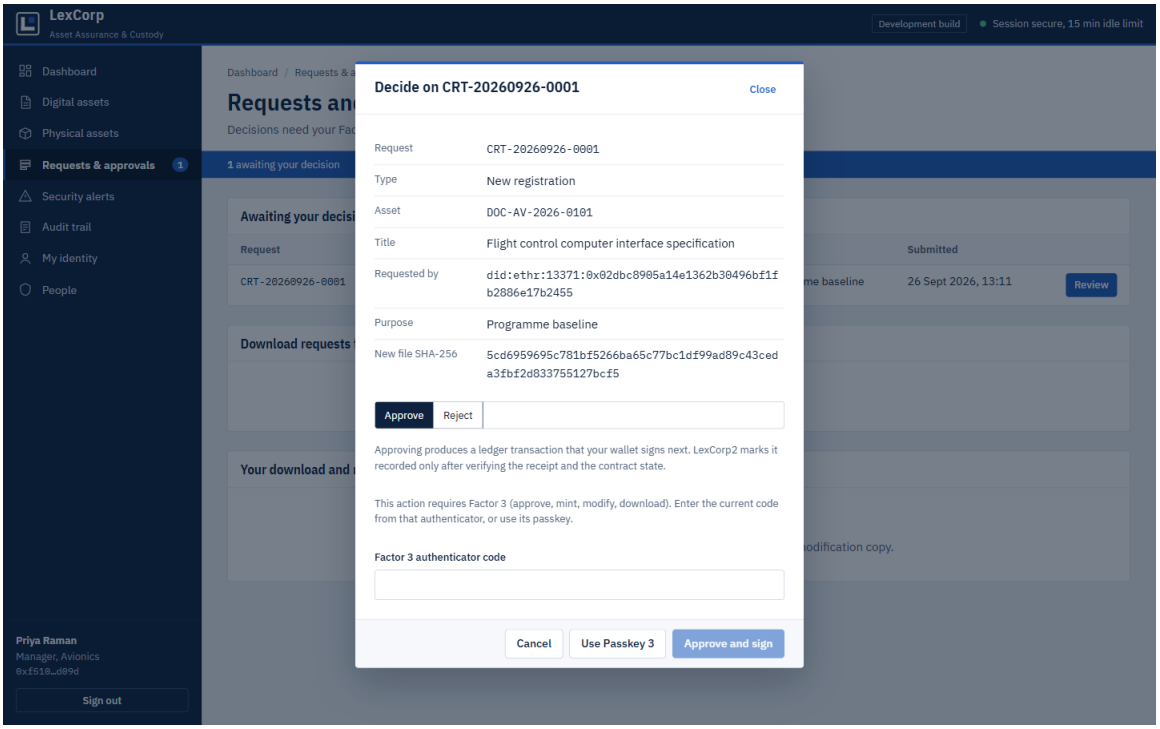



**Figure 18:** *The Manager reviews the creation request and approves it with Factor 3; their wallet signs the mint.*

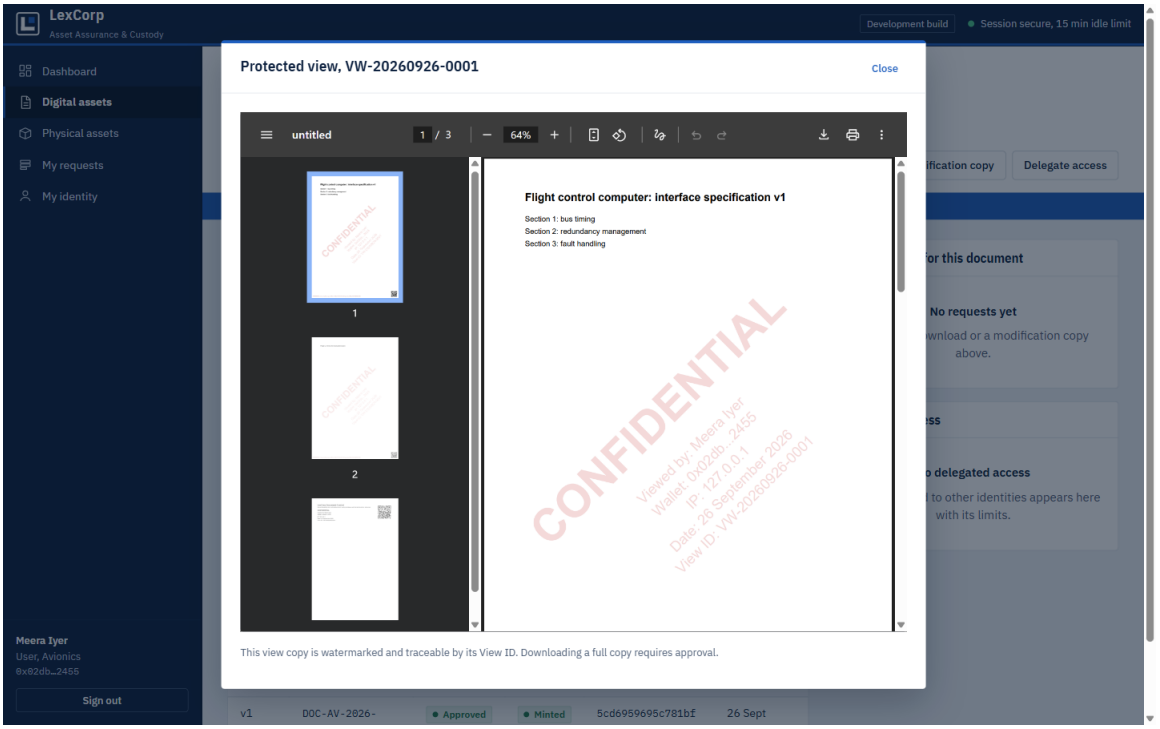



**Figure 19:** *Protected view: the copy is watermarked with the viewer's name, wallet, network address, date, View ID and a QR code.*

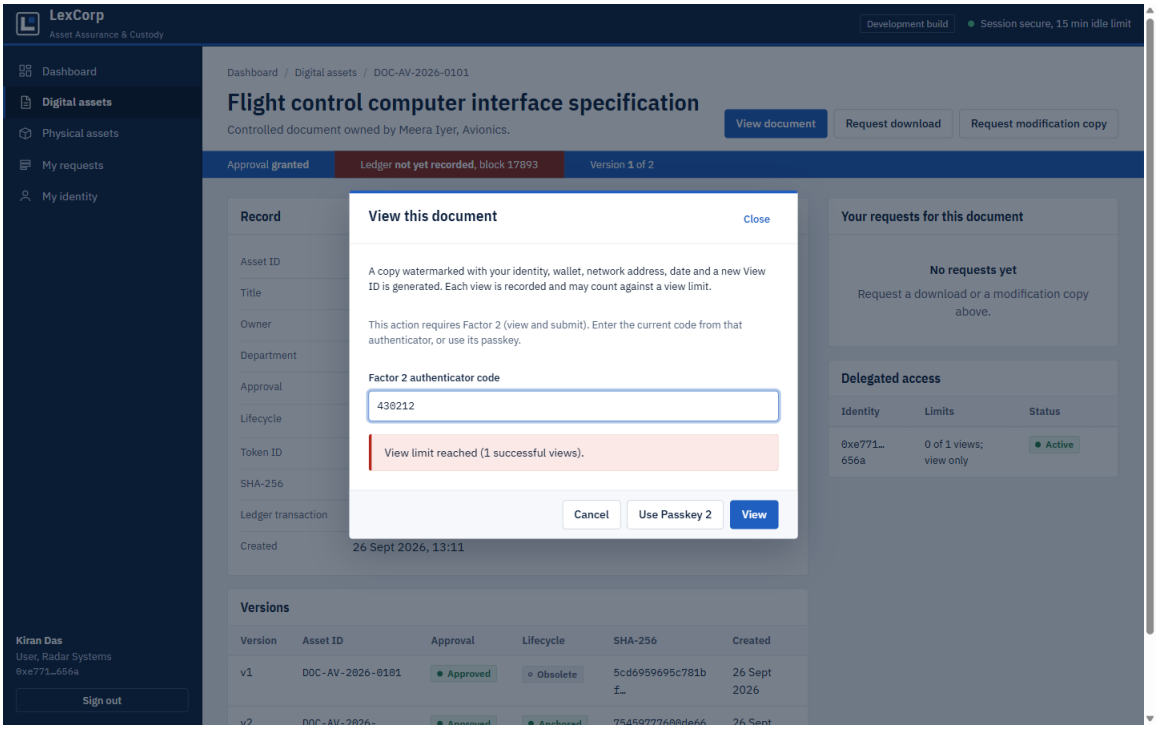



**Figure 20:** *A delegated user who has used both allowed views is refused (view limit reached).*

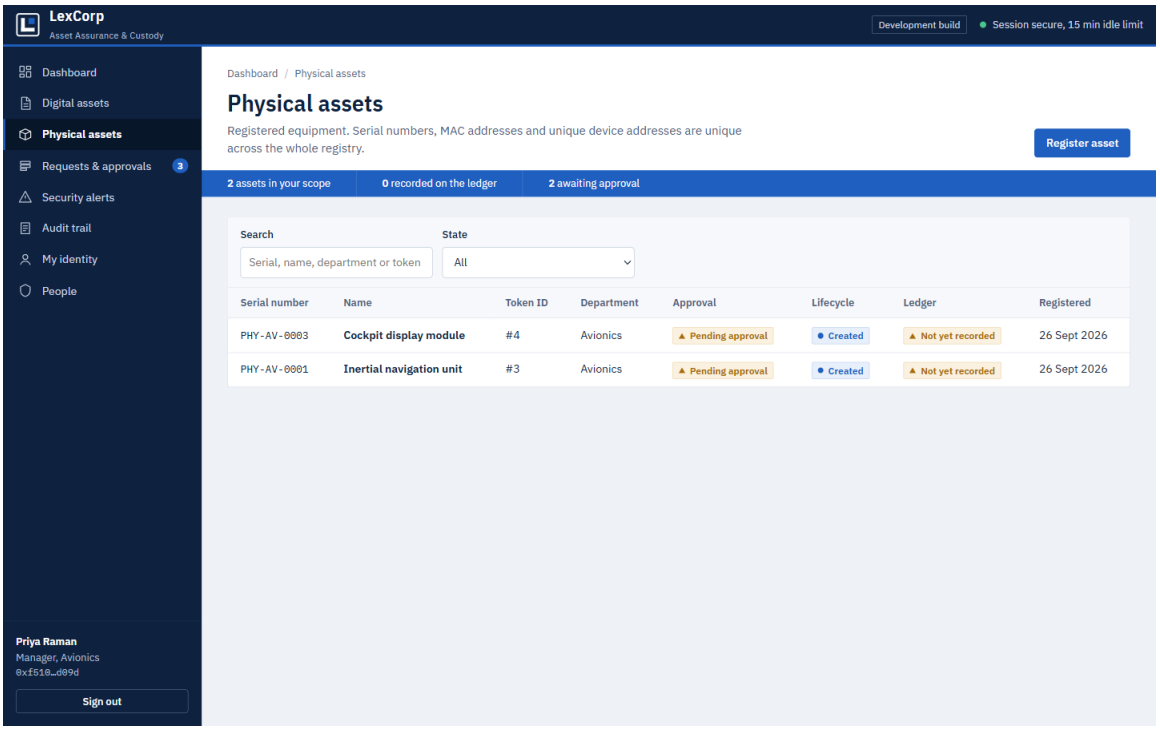



**Figure 21:** *A Manager registers a physical device by serial number and MAC address; duplicates are refused.*

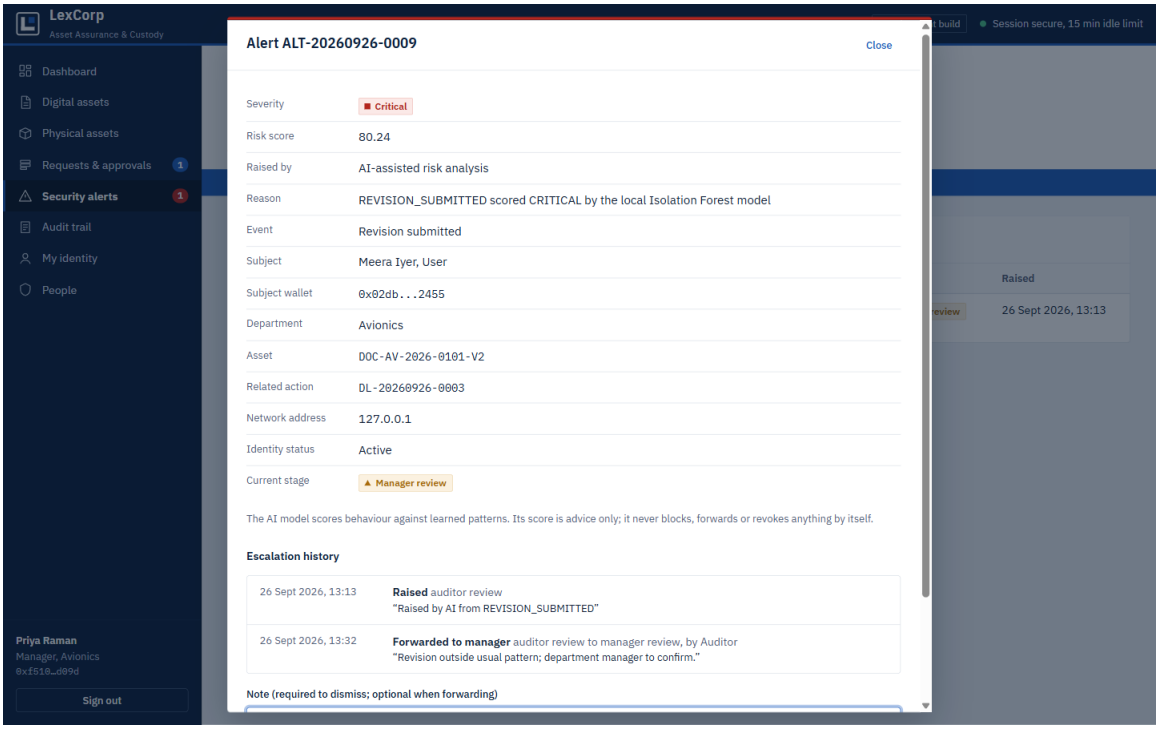



**Figure 22:** *An AI alert at the Manager stage, showing the plain-word reasons and the escalation history.*

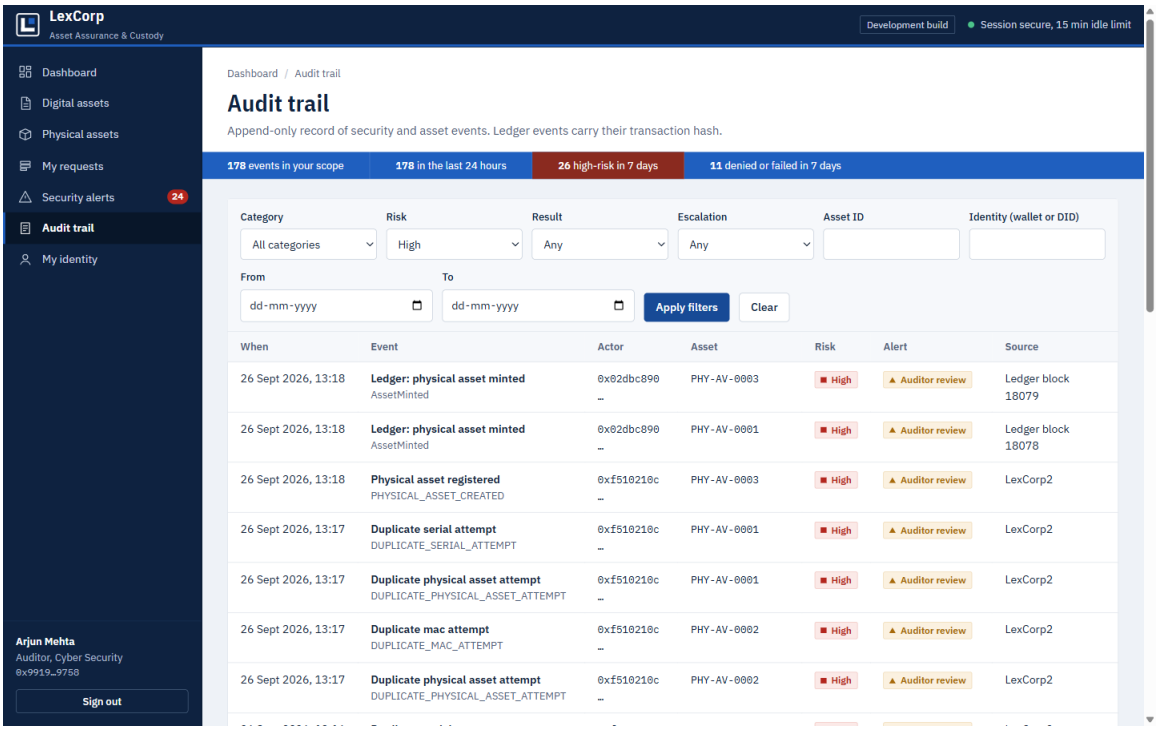



**Figure 23:** *The audit trail filtered to high-risk events; every event shows actor, role, asset, address and risk level.*

# 6 References

[1] IEEE, *IEEE Recommended Practice for Software Requirements Specifications*, IEEE Std 830-1998, IEEE Computer Society, 1998.

[2] B. H. C. Cheng, *SRS template based on IEEE Std 830-1998*, Michigan State University.

[3] R. S. Pressman, *Software Engineering: A Practitioner's Approach*, 7th ed., McGraw-Hill, 2017.

[4] I. Sommerville, *Software Engineering*, 10th ed., Pearson, 2016.

[5] W3C, *Decentralized Identifiers (DIDs) v1.0*, W3C Recommendation, July 2022. Available: https://www.w3.org/TR/did-core/

[6] W. Entriken, D. Shirley, J. Evans and N. Sachs, *EIP-721: Non-Fungible Token Standard*, Ethereum Improvement Proposals, 2018. Available: https://eips.ethereum.org/EIPS/eip-721

[7] Hyperledger Foundation, *Besu documentation: QBFT consensus*. Available: https://besu.hyperledger.org/private-networks/how-to/configure/consensus/qbft

[8] W3C, *Web Authentication: An API for accessing Public Key Credentials, Level 2*, W3C Recommendation, April 2021. Available: https://www.w3.org/TR/webauthn-2/

[9] D. M'Raihi et al., *TOTP: Time-Based One-Time Password Algorithm*, RFC 6238, IETF, May 2011. Available: https://www.rfc-editor.org/rfc/rfc6238

[10] NIST, *Digital Identity Guidelines: Authentication and Lifecycle Management*, SP 800-63B-4, 2025. Available: https://csrc.nist.gov/pubs/sp/800/63/b/4/final

[11] NIST, *Zero Trust Architecture*, SP 800-207, August 2020. Available: https://csrc.nist.gov/pubs/sp/800/207/final

[12] F. T. Liu, K. M. Ting and Z.-H. Zhou, "Isolation Forest," *Proc. IEEE International Conference on Data Mining*, 2008. Available: https://doi.org/10.1109/ICDM.2008.17

[13] Government of India, *Digital Personal Data Protection Act, 2023*, Ministry of Electronics and Information Technology. Available: https://www.meity.gov.in/data-protection-framework

[14] CERT-In, *Directions under sub-section (6) of section 70B of the Information Technology Act, 2000*, 28 April 2022. Available: https://www.cert-in.org.in/Directions70B.jsp

[15] LexCorp project, *Problem Analysis and Feasibility Study*, version 1.0, September 2026 (companion document).

[16] LexCorp project website and source repository: https://github.com/MeezaUni/LexCorp2

# 7 Point of Contact

For further information regarding this document and project, please contact Mohammed Azeemulla Khan (azeemulla555@gmail.com). All materials in this document use test data only; no real personal or organisational data is included.